

Il concetto di "Iniezione"



Il concetto di "Iniezione"

L'idea base

L'hacker non scardina la porta, ma convince il database che l'attacco sia un comando legittimo.

Metafora

È come se un cameriere portasse in cucina un'ordinazione dove, invece di "1 Pizza", c'è scritto: "1 Pizza e poi regalami l'incasso della cassa".

Perché succede?

Perché il database "si fida" ciecamente di ciò che scrive l'utente nel form del sito.

SQL Injection (L'attacco classico)

Scenario

Un modulo di login con Username e Password.

Il trucco

Invece del nome, l'hacker scrive '
OR 1=1 --.

Cosa succede dietro le quinte:

- Query normale: `SELECT * FROM utenti WHERE user = 'mario' AND pass = '123'`
- Query manipolata: `SELECT * FROM utenti WHERE user = " OR 1=1 --" AND pass = '...'`

📄 **Risultato:** Siccome `1=1` è sempre vero, il database apre la porta senza bisogno della password.

NoSQL Injection (L'attacco moderno)

Differenza

Qui non usiamo parole come OR o SELECT, ma usiamo i simboli del linguaggio dei database NoSQL (spesso JSON).

Esempio (MongoDB):

- L'hacker invia questo comando: `{"username": {"$ne": null}, "password": {"$ne": null}}`
- `$ne` significa "Not Equal" (diverso da).

Risultato: Il database cerca un utente dove "lo username non è vuoto" e "la password non è vuota". Praticamente... chiunque!
L'hacker entra nel primo account disponibile (spesso l'admin).

Altri attacchi comuni

Data Exfiltration

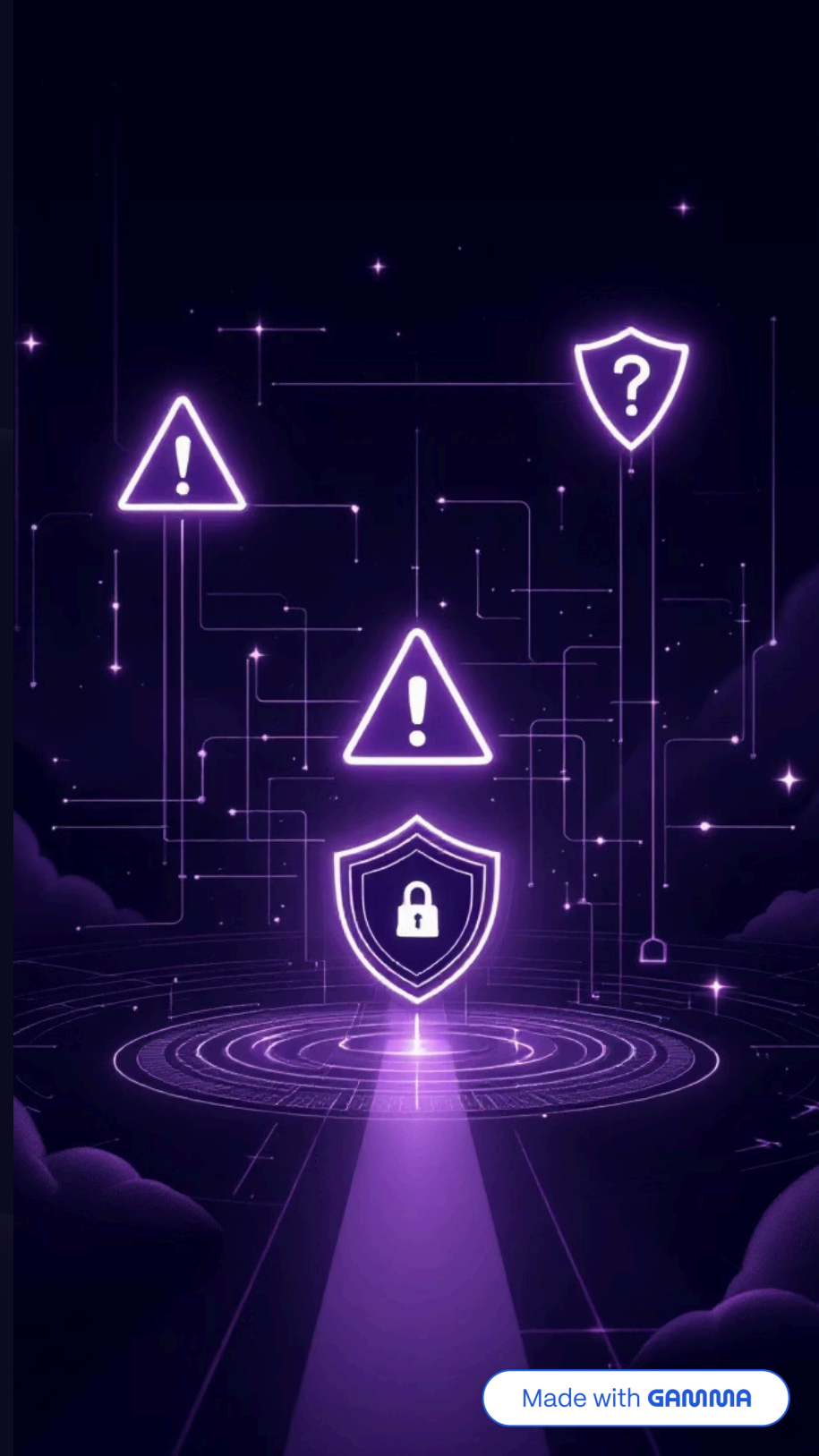
Non solo entrare, ma "svuotare" il database. L'hacker usa comandi per farsi inviare via email o visualizzare a schermo tutta la tabella delle carte di credito.

Denial of Service (DoS)

Inviare una query così complessa e pesante che il database "impazzisce", la CPU va al 100% e il sito smette di funzionare per tutti.

Ransomware sui DB

Entrare nei database NoSQL non protetti (senza password), cancellare tutto e lasciare un messaggio: "Paga in Bitcoin per riavere i tuoi dati".



Come ci difendiamo? (La parte "Blue Team")

01

Sanitizzazione

Controllare sempre cosa scrive l'utente. Se chiedo un'età, non devo accettare lettere o simboli strani.

02

Prepared Statements (SQL)

È come inviare in cucina un modulo pre-stampato dove il cliente può solo scrivere il numero della pizza, senza poter aggiungere "frasi extra".

03

Password e Firewall

Sembra banale, ma molti database NoSQL vengono hackerati solo perché non hanno una password o sono aperti su internet senza protezione.

04

Cifratura

Se anche l'hacker ruba i dati, deve trovarli "criptati" (illeggibili).

Esempio Visuale - Difesa vs Attacco

Inserisce ' OR 1=1	Il DB esegue il comando	Il sistema vede simboli strani e blocca tutto
Cerca di accedere senza pass	Il DB NoSQL risponde (default)	Il Firewall blocca la richiesta esterna
Scarica tutta la tabella	I dati sono in chiaro (Leggibili)	I dati sono cifrati (Inutilizzabili)